

AEGIS-API

Unified API Security Assessment Report

Assessment Date: 2026-05-27 17:47:59

Protocols Tested: Soap

Soap: <http://localhost:8000>

CONFIDENTIAL — For authorized recipient only. Do not distribute without permission.

SECTION 1 — EXECUTIVE SUMMARY

Aegis-API completed a unified API security assessment covering **Soap** API protocols. A total of **4 vulnerabilities** were identified. The overall risk rating for this assessment is: **High**.

Vulnerability Distribution by Severity

Severity	Count	Risk Level
Critical	0	Immediate action required
High	1	Fix within sprint
Medium	3	Fix within quarter
Low	0	Best effort
Info	0	Informational

Vulnerability Distribution by Protocol

Protocol	Findings	Target URL
Soap	0	http://localhost:8000

Key Recommendations

- [High] Remediate **Sensitive Operation Exposed in WSDL: AdminReset** in the SOAP layer — maps to UNKNOWN: Unknown.

SECTION 2 — SCOPE AND METHODOLOGY

Assessment Date: 2026-05-27 17:47:59

Target Scope

Protocol	Target URL	Discovery Method
Soap	http://localhost:8000	Manual

Testing Methodology by Protocol

OWASP API Top 10 Coverage Matrix

OWASP ID	Category	REST	SOAP	GraphQL
API1	Broken Object Level Authorization (BOLA/...	✓ IDOR/BOLA	—	✓ Field auth
API2	Broken Authentication...	✓ JWT	✓ WS-Security	✓ JWT
API3	Broken Object Property Level Authorizati...	✓ Mass Assignment	—	✓ Mutation inject
API4	Unrestricted Resource Consumption...	✓ Rate limit	—	✓ Depth + Batch
API7	Server Side Request Forgery...	—	✓ XXE/SSRF	—
API8	Security Misconfiguration...	—	✓ WSDL exposure	✓ Introspection

SECTION 3 — DETAILED FINDINGS

Finding 1: Sensitive Operation Exposed in WSDL: AdminReset

Protocol	SOAP	Severity	High
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

The operation 'AdminReset' is publicly listed in the WSDL and its name suggests privileged or administrative functionality. SOAPAction: http://fakebank.local/soap/AdminReset. An attacker can attempt to call this operation directly.

Remediation

Remove internal and admin operations from the public-facing WSDL. Apply authentication and authorization checks at the operation level, not just at the network perimeter.

Finding 2: WSDL Publicly Accessible — Service Contract Exposed

Protocol	SOAP	Severity	Medium
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

The WSDL document is publicly accessible without authentication. WSDL exposes the complete service contract including all operation names, parameter names, data types, and endpoint URLs. Attackers use this information to map the attack surface before targeting individual operations.

Remediation

Restrict WSDL access to authenticated and authorized clients only. If WSDL must be public, ensure no internal or admin operations are listed. Consider returning a sanitized WSDL for public consumption.

Finding 3: IDOR Risk Parameter in Operation: GetUser

Protocol	SOAP	Severity	Medium
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

The operation 'GetUser' accepts a parameter 'userId' which appears to be a direct object reference. If authorization is not enforced server-side, an attacker can enumerate IDs to access other users' data.

Remediation

Validate that the authenticated user is authorized to access the requested object ID on every SOAP operation call. Do not rely on obscurity of IDs.

Finding 4: IDOR Risk Parameter in Operation: CreateOrder

Protocol	SOAP	Severity	Medium
OWASP ID	UNKNOWN	OWASP Category	Unknown
CVSS Score	N/A	CVSS Justification	

Description

The operation 'CreateOrder' accepts a parameter 'userId' which appears to be a direct object reference. If authorization is not enforced server-side, an attacker can enumerate IDs to access other users' data.

Remediation

Validate that the authenticated user is authorized to access the requested object ID on every SOAP operation call. Do not rely on obscurity of IDs.

SECTION 4 — REMEDIATION SUMMARY TABLE

#	Finding	Protocol	Severity	OWASP	Fix Effort	Priority
1	Sensitive Operation Exposed in WSDL	SOAP	High	UNKNOWN	Short-term (< 1 week)	P2
2	WSDL Publicly Accessible — Service	SOAP	Medium	UNKNOWN	Medium-term (< 1 month)	P3
3	IDOR Risk Parameter in Operation: G	SOAP	Medium	UNKNOWN	Medium-term (< 1 month)	P3
4	IDOR Risk Parameter in Operation: C	SOAP	Medium	UNKNOWN	Medium-term (< 1 month)	P3

SECTION 5 — APPENDIX

A — Tool Configuration

```
target: http://localhost:8000
protocol: auto
proxy: disabled
auth_provided: False
wordlist: default
params: default
```

B — Raw Audit Log (last 50 entries)

```
=====
Aegis-API Evidence File - 2026-05-27 17:47:59
=====
```

```
Type:      WSDL Publicly Accessible - Service Contract Exposed
```

```
Protocol:  SOAP
```

```
OWASP:     {'id': 'API7:2023', 'name': 'Server Side Request Forgery (SSRF) / Security Misconfiguration',
```

```
URL:       N/A
```

```
Status:    N/A
```

```
Evidence:
```

```
"WSDL retrieved from: http://localhost:8000?wsdl"
```

```
-----
Type:      Sensitive Operation Exposed in WSDL: AdminReset
```

```
Protocol:  SOAP
```

```
OWASP:     {'id': 'API7:2023', 'name': 'Server Side Request Forgery (SSRF) / Security Misconfiguration',
```

```
URL:       N/A
```

```
Status:    N/A
```

```
Evidence:
```

```
"Operation name: AdminReset\nSOAPAction: http://fakebank.local/soap/AdminReset\nParameters: ['adminToken"
```

```
-----
Type:      IDOR Risk Parameter in Operation: GetUser
```

```
Protocol:  SOAP
```

```
OWASP:     {'id': 'API11:2023', 'name': 'Broken Object Level Authorization (BOLA/IDOR)', 'description': 'A
```

```
URL:       N/A
```

```
Status:    N/A
```

```
Evidence:
```

```
"Operation: GetUser\nParameter: userId (type: xsd:integer)\nSOAPAction: http://fakebank.local/soap/GetU
```

```
-----
Type:      IDOR Risk Parameter in Operation: CreateOrder
```

```
Protocol:  SOAP
```

OWASP: {'id': 'API1:2023', 'name': 'Broken Object Level Authorization (BOLA/IDOR)', 'description': 'A
URL: N/A
Status: N/A
Evidence:
"Operation: CreateOrder\nParameter: userId (type: xsd:integer)\nSOAPAction: http://fakebank.local/soap/0

C — References

- OWASP API Security Top 10 (2023): <https://owasp.org/API-Security/>
- CVSS v3.1 Calculator: <https://www.first.org/cvss/calculator/3.1>
- crAPI Vulnerable REST Lab: <https://github.com/OWASP/crAPI>
- DVGA Vulnerable GraphQL Lab: <https://github.com/dolevf/Damn-Vulnerable-GraphQL-Application>
- WebGoat SOAP Lab: <https://github.com/WebGoat/WebGoat>
- JWT Security Best Practices:
https://cheatsheetseries.owasp.org/cheatsheets/JSON_Web_Token_Cheat_Sheet.html
- XXE Prevention:
https://cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html